

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Mon 18 May 2026, at 16:58:58

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=High, Confidence=Medium \(2\)](#)
 - [Risk=Medium, Confidence=High \(2\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Medium, Confidence=Low \(1\)](#)

- [Risk=Low, Confidence=High \(2\)](#).
- [Risk=Low, Confidence=Medium \(5\)](#).
- [Risk=Informational, Confidence=Medium \(3\)](#).
- [Risk=Informational, Confidence=Low \(1\)](#).
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://www.google.com>
- <https://demo.testfire.net>
- <http://demo.testfire.net>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	2 (11.1%)	0 (0.0%)	2 (11.1%)
	Medium	0 (0.0%)	2 (11.1%)	2 (11.1%)	1 (5.6%)	5 (27.8%)
	Low	0 (0.0%)	2 (11.1%)	5 (27.8%)	0 (0.0%)	7 (38.9%)
	Informational	0 (0.0%)	0 (0.0%)	3 (16.7%)	1 (5.6%)	4 (22.2%)
	1					
	Total	0 (0.0%)	4 (22.2%)	12 (66.7%)	2 (11.1%)	18 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Site	Risk			Informational
	High (= High)	Medium (>= Medium)	Low (>= Low)	(>= Informational)
https://demo.testfire.net	0 (0)	1 (1)	3 (4)	1 (5)
http://demo.testfire.net	2 (2)	4 (6)	4 (10)	3 (13)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Cross Site Scripting_(Reflected)	High	2 (11.1%)
SQL Injection	High	3 (16.7%)
Absence of Anti-CSRF Tokens	Medium	6 (33.3%)
Total		18

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	10 (55.6%)
Missing Anti-clickjacking Header	Medium	10 (55.6%)
Secure Pages Include Mixed Content (Including Scripts)	Medium	1 (5.6%)
Sub Resource Integrity Attribute Missing	Medium	2 (11.1%)
Cookie without SameSite Attribute	Low	6 (33.3%)
Cross-Domain JavaScript Source File Inclusion	Low	2 (11.1%)
Information Disclosure - Debug Error Messages	Low	2 (11.1%)
Secure Pages Include Mixed Content	Low	2 (11.1%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	10 (55.6%)
Strict-Transport-Security Header Not Set	Low	5 (27.8%)
X-Content-Type-Options Header Missing	Low	10 (55.6%)
Information Disclosure - Suspicious Comments	Informational	12 (66.7%)
Modern Web Application	Informational	8 (44.4%)
Total		18

Alert type	Risk	Count
Re-examine Cache-control Directives	Informational	5 (27.8%)
Session Management Response Identified	Informational	13 (72.2%)
Total		18

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Medium	Exceeded Low		Percentage of memory used	83
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Warning		ZAP warnings logged - see the zap.log file for details	77
Low	Exceeded High	http://demo.testfire.net	Percentage of slow responses	100 %
Low	Exceeded High	https://demo.testfire.net	Percentage of slow responses	100 %

Level	Reason	Site	Description	Statistic
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 2xx	54 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 3xx	14 %
Info	Exceeded Low	http://demo.testfire.net	Percentage of responses with status code 4xx	30 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/javascript	2 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/json	3 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/pdf	1 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/x-shockwave-flash	1 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type image/gif	7 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type image/jpeg	27 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type image/png	2 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type text/css	2 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type text/html	48 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with method GET	96 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with method POST	3 %
Info	Informational	http://demo.testfire.net	Count of total endpoints	90

Level	Reason	Site	Description	Statistic
Info	Informational	https://demo.testfir.e.net	Percentage of responses with status code 2xx	96 %
Info	Informational	https://demo.testfir.e.net	Percentage of responses with status code 4xx	3 %
Info	Informational	https://demo.testfir.e.net	Percentage of endpoints with content type application/javascript	3 %
Info	Informational	https://demo.testfir.e.net	Percentage of endpoints with content type application/json	4 %
Info	Informational	https://demo.testfir.e.net	Percentage of endpoints with content type image/gif	9 %
Info	Informational	https://demo.testfir.e.net	Percentage of endpoints with content type image/jpeg	39 %
Info	Informational	https://demo.testfir.e.net	Percentage of endpoints with content type image/png	1 %
Info	Informational	https://demo.testfir.e.net	Percentage of endpoints with content type text/css	3 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://demo.testfire.net	Percentage of endpoints with content type text/html	39 %
Info	Informational	https://demo.testfire.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://demo.testfire.net	Count of total endpoints	64
Info	Informational	https://www.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.google.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informational	https://www.google.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://www.google.com	Count of total endpoints	1
Info	Informational	https://www.google.com	Percentage of slow responses	100 %

Alerts

Risk=High, Confidence=Medium (2)

<http://demo.testfire.net> (2)

Cross Site Scripting_(Reflected) (1)

► POST <http://demo.testfire.net/sendFeedback>

SQL Injection (1)

► POST <http://demo.testfire.net/doLogin>

Risk=Medium, Confidence=High (2)

<http://demo.testfire.net> (2)

Content Security Policy (CSP) Header Not Set (1)

► GET <http://demo.testfire.net/robots.txt>

Sub Resource Integrity Attribute Missing (1)

► GET [http://demo.testfire.net/index.jsp?
content=personal_investments.htm](http://demo.testfire.net/index.jsp?content=personal_investments.htm)

Risk=Medium, Confidence=Medium (2)

<https://demo.testfire.net> (1)

Secure Pages Include Mixed Content (Including Scripts) (1)

► GET [https://demo.testfire.net/index.jsp?
content=personal_investments.htm](https://demo.testfire.net/index.jsp?content=personal_investments.htm)

<http://demo.testfire.net> (1)

Missing Anti-clickjacking Header (1)

► GET <http://demo.testfire.net/>

Risk=Medium, Confidence=Low (1)

<http://demo.testfire.net> (1)

Absence of Anti-CSRF Tokens (1)

► GET <http://demo.testfire.net/login.jsp>

Risk=Low, Confidence=High (2)

<https://demo.testfire.net> (1)

Strict-Transport-Security Header Not Set (1)

► GET <https://demo.testfire.net/images/logo.gif>

<http://demo.testfire.net> (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

► GET <http://demo.testfire.net/sitemap.xml>

Risk=Low, Confidence=Medium (5)

<https://demo.testfire.net> (2)

Information Disclosure - Debug Error Messages (1)

- ▶ GET https://demo.testfire.net/swagger/properties.json

Secure Pages Include Mixed Content (1)

- ▶ GET https://demo.testfire.net/index.jsp?
content=inside_contact.htm

http://demo.testfire.net (3)

Cookie without SameSite Attribute (1)

- ▶ GET http://demo.testfire.net/robots.txt

Cross-Domain JavaScript Source File Inclusion (1)

- ▶ GET http://demo.testfire.net/index.jsp?
content=personal_investments.htm

X-Content-Type-Options Header Missing (1)

- ▶ GET http://demo.testfire.net/

Risk=Informational, Confidence=Medium (3)

http://demo.testfire.net (3)

Information Disclosure - Suspicious Comments (1)

- ▶ GET http://demo.testfire.net/login.jsp

Modern Web Application (1)

- ▶ GET http://demo.testfire.net/index.jsp?content=inside.htm

Session Management Response Identified (1)

► GET http://demo.testfire.net/robots.txt

Risk=Informational, Confidence=Low (1)

<https://demo.testfire.net> (1)

Re-examine Cache-control Directives (1)

► GET https://demo.testfire.net/

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Cross Site Scripting (Reflected)

Source	raised by an active scanner (Cross Site Scripting (Reflected))
CWE ID	79
WASC ID	8
Reference	▪ https://owasp.org/www-community/attacks/xss/ ▪ https://cwe.mitre.org/data/definitions/79.html

SQL Injection

Source	raised by an active scanner (SQL Injection)
--------	---

CWE ID	<u>89</u>
WASC ID	19
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	<u>352</u>
WASC ID	9
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	<u>693</u>
WASC ID	15
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets

[s/Content_Security_Policy_Cheat_Sheet.html](https://www.w3.org/TR/CSP/)

- <https://www.w3.org/TR/CSP/>
- <https://w3c.github.io/webappsec-csp/>
- <https://web.dev/articles/csp>
- <https://caniuse.com/#feat=contentsecuritypolicy>
- <https://content-security-policy.com/>

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Secure Pages Include Mixed Content (Including Scripts)

Source	raised by a passive scanner (Secure Pages Include Mixed Content)
CWE ID	311
WASC ID	4
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html

Sub Resource Integrity Attribute Missing

Source	raised by a passive scanner (Sub Resource Integrity Attribute Missing)
CWE ID	345
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Cross-Domain JavaScript Source File Inclusion

Source	raised by a passive scanner (Cross-Domain JavaScript Source File Inclusion)
CWE ID	829
WASC ID	15

Information Disclosure - Debug Error Messages

Source	raised by a passive scanner (Information Disclosure - Debug Error Messages)
CWE ID	1295

Secure Pages Include Mixed Content

Source	raised by a passive scanner (Secure Pages Include Mixed Content)
CWE ID	311
WASC ID	4
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Strict-Transport-Security Header Not Set

Source	raised by a passive scanner (Strict-Transport-Security Header)
--------	--

CWE ID	<u>319</u>
WASC ID	15
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html ▪ https://owasp.org/www-community/Security-Headers ▪ https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security ▪ https://caniuse.com/stricttransportsecurity ▪ https://datatracker.ietf.org/doc/html/rfc6797

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	<u>693</u>
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
---------------	--

CWE ID [615](#)

WASC ID 13

Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

Re-examine Cache-control Directives

Source raised by a passive scanner ([Re-examine Cache-control Directives](#))

CWE ID [525](#)

WASC ID 13

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
- <https://grayduck.mn/2021/09/13/cache-control-recommendations/>

Session Management Response Identified

Source raised by a passive scanner ([Session Management Response Identified](#))

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/>

